



Symantec Certificate Authority Trust Crisis

By: Dennis Kalnin & Nathan Toner



Symantec PKI Trust Crisis

What Happened?

- Symantec operated one of the world's largest Certificate Authority infrastructures.
- Its CA brands included VeriSign, GeoTrust, Thawte, and RapidSSL.
- Investigations found certificates that did not follow CA/Browser Forum requirements.
- The issue grew from a relatively small number of questionable certificates to at least 30,000.
- Google eventually concluded it could no longer trust Symantec's certificate infrastructure.

Root Cause

What Went Wrong?

- Symantec allowed outside organizations to participate in certificate issuance.
- Some organizations were given this ability without sufficient oversight.
- Google said Symantec had known about security deficiencies involving some of these organizations.
- Certificate validation and auditing controls were not strong enough.
- Repeated incidents caused browsers to lose confidence in Symantec's entire PKI rather than just individual certificates



Industry & Symantec Response

What Did They Do?

- Google announced plans to gradually remove trust in Symantec certificates.
- Chrome 66 began distrusting older Symantec-issued certificates.
- Chrome 70 ultimately removed trust in Symantec's legacy PKI.
- Website owners had to replace affected certificates with certificates from another trusted infrastructure.
- Symantec selected DigiCert to operate new certificate infrastructure.
- Symantec ultimately sold its website-security and PKI business to DigiCert.

Lesson Learned

Key Takeaways

- **Trust is essential:** A Certificate Authority survives on trust, not just encryption.
- **Strict validation:** Certificate issuance requires strong validation and regular auditing.
- **Third-party risk:** Third parties should only receive certificate-issuing authority with strict controls and monitoring.
- **Certificate Transparency:** Helps researchers and browser vendors detect questionable certificates.
- **Loss of trust:** Repeated security failures can cause an entire CA to be removed from browser trust stores.
- **Major consequences:** Losing CA trust can create serious technical, financial, and reputational consequences.